Executive Security Report

ACME Corp (demo)

Generated 2026-10-25 19:39 UTC by examples

Scope: 8 network asset(s), host audit of web-prod-01, traffic capture 'demo:sensor-eth0'

RISK SCORE	SECURITY POSTURE	OPEN FINDINGS	CRITICAL	HIGH	ASSETS	COMPLIANCE	NETWORK HEALTH
100/100	**0/100**	**57**	**13**	**17**	**8**	**9%**	**0/100**

Summary

The assessment identified 57 open finding(s): 13 critical, 17 high, 16 medium and 11 low. The aggregated risk score is 100/100, which corresponds to a critical level of risk. Critical findings must be remediated immediately (P1, 24-72 hours). Overall technical compliance is 9% (critical posture). CIS Critical Security Controls v8: 15% (2 passed, 1 partial, 9 failed, 0 not assessed). NIST Cybersecurity Framework: 12% (1 passed, 0 partial, 10 failed, 0 not assessed). ISO/IEC 27001:2022 Annex A: 0% (0 passed, 0 partial, 10 failed, 0 not assessed). 10 priority-1 gap(s) require immediate attention, notably: CIS-4.1 Establish and Maintain a Secure Configuration Process; CIS-4.4 Implement and Manage a Firewall on Servers; CIS-5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts. 30 finding(s) sit in the high-risk zone of the risk matrix. Network health score of the latest capture is 0/100 with 13 anomaly(ies).

Severity matrix

Category	Critical	High	Medium	Low	Informational	Total
accounts	2			1		3
exposure	1	2	3	2		8
filesystem		1				1
firewall		1				1
logging				1		1
network		1				1
password_policy			2			2
patching				1		1
privilege		1		1		2
ssh		1	2	4		7
traffic	1	4	6	1		12
vulnerability	9	6	3			18
Total	**13**	**17**	**16**	**11**	**0**	**57**

Risk matrix (likelihood x impact)

Likelihood \ Impact	Negligible	Minor	Moderate	Major	Severe
Almost certain				3	11
Likely			3	14	2
Possible			13		
Unlikely		11			
Rare					

Compliance

Framework	Score	Passed	Partial	Failed	Not assessed
CIS Critical Security Controls v8	15%	2	1	9	0
NIST Cybersecurity Framework	12%	1	0	10	0
ISO/IEC 27001:2022 Annex A	0%	0	0	10	0

Gap analysis - CIS Critical Security Controls v8

Priority	Control	Status	Recommendation
P1	CIS-4.1 Establish and Maintain a Secure Configuration Process	FAIL	Adopt a hardened baseline (CIS Benchmark) and enforce it with configuration management.
P1	CIS-4.4 Implement and Manage a Firewall on Servers	FAIL	Enable a default-deny host firewall on every server.
P1	CIS-5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts	FAIL	Disable direct root login, remove duplicate UID 0 accounts and require authentication for sudo.
P1	CIS-7.7 Remediate Detected Vulnerabilities	FAIL	Remediate critical vulnerabilities within 72 hours and high within 7 days.

Gap analysis - NIST Cybersecurity Framework

Priority	Control	Status	Recommendation
P1	PR.AA-01 Identities and credentials for authorized users, services, and hardware are managed	FAIL	Review accounts, enforce password policy and lock unused/system accounts.
P1	PR.AA-05 Access permissions are managed, incorporating least privilege	FAIL	Apply least privilege for sudo, root access and sensitive file permissions.
P1	PR.IR-01 Networks and environments are protected from unauthorized logical access and usage	FAIL	Filter inbound traffic with host and network firewalls; restrict exposed services.

Gap analysis - ISO/IEC 27001:2022 Annex A

Priority	Control	Status	Recommendation
P1	A.8.2 Privileged access rights	FAIL	Restrict and log privileged access.
P1	A.8.20 Networks security	FAIL	Secure, manage and control networks and filter traffic.
P1	A.8.8 Management of technical vulnerabilities	FAIL	Identify vulnerabilities timely, evaluate exposure and remediate.

Findings (top 15 of 57)

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2021-42013

Identifier	CVE-2021-42013 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Incomplete fix for CVE-2021-41773: path traversal and remote code execution in Apache HTTP Server 2.4.49 and 2.4.50. A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (versions 2.4.49, 2.4.50).
Recommendation	Upgrade Apache HTTP Server to 2.4.51 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-42013

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2022-22720

Identifier	CVE-2022-22720 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Apache HTTP Server 2.4.52 and earlier fails to close the inbound connection when errors are encountered discarding the request body, exposing the server to HTTP request smuggling.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (<= 2.4.52).
Recommendation	Upgrade Apache HTTP Server to 2.4.53 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2022-22720

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2023-25690

Identifier	CVE-2023-25690 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Some mod_proxy configurations on Apache HTTP Server 2.4.0 through 2.4.55 allow HTTP request smuggling.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (>= 2.4.0 and <= 2.4.55).
Recommendation	Upgrade Apache HTTP Server to 2.4.56 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-25690

CRITICAL OpenSSH 8.9p1 affected by CVE-2023-38408

Identifier	CVE-2023-38408 | CVSS 9.8 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	The PKCS#11 feature in ssh-agent has an insufficiently trustworthy search path, leading to remote code execution if an agent is forwarded to an attacker-controlled system.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (< 9.3p2).
Recommendation	Upgrade OpenSSH to 9.3p2 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-38408

CRITICAL vsftpd 2.3.4 affected by CVE-2011-2523

Identifier	CVE-2011-2523 | CVSS 9.8 | confidence high
Asset	10.10.0.11:21 | vulnerability | vulnerability_analyzer
Description	vsftpd 2.3.4 downloaded between 2011-06-30 and 2011-07-03 contains a backdoor which opens a shell on port 6200/tcp. A public exploit is available.
Evidence	21/tcp banner 'vsftpd 2.3.4' matches affected range (versions 2.3.4).
Recommendation	Upgrade vsftpd to 2.3.5 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2011-2523

CRITICAL Samba 4.5.9 affected by CVE-2017-7494

Identifier	CVE-2017-7494 | CVSS 9.8 | confidence high
Asset	10.10.0.11:445 | vulnerability | vulnerability_analyzer
Description	SambaCry: a malicious client can upload a shared library to a writable share and cause the server to load and execute it (remote code execution). A public exploit is available.
Evidence	445/tcp banner 'Samba smbd 4.5.9 workgroup: CORP' matches affected range (>= 4.5.0 and < 4.5.10).
Recommendation	Upgrade Samba to 4.6.4 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2017-7494

CRITICAL OpenSSH 7.4 affected by CVE-2023-38408

Identifier	CVE-2023-38408 | CVSS 9.8 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	The PKCS#11 feature in ssh-agent has an insufficiently trustworthy search path, leading to remote code execution if an agent is forwarded to an attacker-controlled system.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (< 9.3p2).
Recommendation	Upgrade OpenSSH to 9.3p2 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-38408

CRITICAL Exim 4.89 affected by CVE-2019-10149

Identifier	CVE-2019-10149 | CVSS 9.8 | confidence high
Asset	10.10.0.12:25 | vulnerability | vulnerability_analyzer
Description	Improper validation of recipient addresses in deliver_message() in Exim 4.87 to 4.91 allows remote command execution ("Return of the WIZard"). A public exploit is available.
Evidence	25/tcp banner 'Exim smtpd 4.89' matches affected range (>= 4.87 and <= 4.91).
Recommendation	Upgrade Exim to 4.92 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2019-10149

CRITICAL Apache Tomcat 9.0.30 affected by CVE-2020-1938

Identifier	CVE-2020-1938 | CVSS 9.8 | confidence high
Asset	10.10.0.13:8080 | vulnerability | vulnerability_analyzer
Description	Ghostcat: the AJP connector trusts incoming connections by default, allowing file read/inclusion (and RCE when uploads are possible) in Apache Tomcat. A public exploit is available.
Evidence	8080/tcp banner 'Apache Tomcat 9.0.30' matches affected range (>= 9.0.0.M1 and < 9.0.31).
Recommendation	Upgrade Apache Tomcat to 9.0.31 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2020-1938

CRITICAL Communication with known malicious IP 203.0.113.50

Identifier	TRF-IOC-IP | confidence high
Asset	10.10.0.13 | traffic | traffic_monitor
Evidence	41943 packets / 62914500 bytes exchanged with 203.0.113.50 (IOC 203.0.113.50, source cybershield-sample: Sample data exfiltration endpoint)
Recommendation	Isolate the host, block the indicator at the perimeter, and start incident response (collect volatile evidence before remediation).

CRITICAL Docker Engine API exposed without TLS

Identifier	EXP-DOCKER | confidence high
Asset	10.10.0.21:2375 | exposure | vulnerability_analyzer
Description	Docker Engine API exposed without TLS on 10.10.0.21:2375/tcp.
Evidence	2375/tcp docker Docker 20.10.7
Recommendation	Never expose the Docker socket over TCP without mutual TLS; bind to a unix socket only.

CRITICAL No duplicate UID 0 (root-equivalent) accounts

Identifier	USR-001 | confidence high
Asset	web-prod-01 | accounts | system_auditor
Evidence	Accounts with UID 0 besides root: svc-backup
Recommendation	Only 'root' may have UID 0. Investigate and remove/renumber other UID 0 accounts immediately.
References	CIS Debian/Ubuntu Benchmark 7.2.x | NIST CSF PR.AA-05

CRITICAL No accounts with empty passwords

Identifier	USR-002 | confidence high
Asset	web-prod-01 | accounts | system_auditor
Evidence	Accounts with empty password: svc-backup
Recommendation	Lock or set a strong password on every account with an empty password field (`passwd -l <user>`).
References	CIS Debian/Ubuntu Benchmark 7.2.x | ISO 27001 A.5.17

HIGH

OpenSSH 8.9p1 affected by CVE-2024-6387

Identifier	CVE-2024-6387 | CVSS 8.1 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	regreSSHion: a signal handler race condition in sshd's SIGALRM handling (LoginGraceTime) can allow unauthenticated remote code execution as root on glibc-based Linux systems.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (>= 8.5p1 and < 9.8p1).
Recommendation	Upgrade OpenSSH to 9.8p1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2024-6387 | https://www.qualys.com/2024/07/01/cve-2024-6387/regresshion.txt

HIGH

OpenSSH 9.7p1 affected by CVE-2024-6387

Identifier	CVE-2024-6387 | CVSS 8.1 | confidence high
Asset	10.10.0.12:22 | vulnerability | vulnerability_analyzer
Description	regreSSHion: a signal handler race condition in sshd's SIGALRM handling (LoginGraceTime) can allow unauthenticated remote code execution as root on glibc-based Linux systems.
Evidence	22/tcp banner 'OpenSSH 9.7p1 protocol 2.0' matches affected range (>= 8.5p1 and < 9.8p1).
Recommendation	Upgrade OpenSSH to 9.8p1 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2024-6387 | https://www.qualys.com/2024/07/01/cve-2024-6387/regresshion.txt

Recommendations

1. Upgrade Apache HTTP Server to 2.4.51 or later.

2. Upgrade Apache HTTP Server to 2.4.53 or later.

3. Upgrade Apache HTTP Server to 2.4.56 or later.

4. Upgrade OpenSSH to 9.3p2 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.

5. Upgrade vsftpd to 2.3.5 or later.

6. Upgrade Samba to 4.6.4 or later.

7. Upgrade OpenSSH to 9.3p2 or later.

8. Upgrade Exim to 4.92 or later.

9. Upgrade Apache Tomcat to 9.0.31 or later.

10. Isolate the host, block the indicator at the perimeter, and start incident response (collect volatile evidence before remediation).

11. Never expose the Docker socket over TCP without mutual TLS; bind to a unix socket only.

12. Only 'root' may have UID 0. Investigate and remove/renumber other UID 0 accounts immediately.

Remediation priorities

Priority	Severity	Target	Count	Examples
P1 Immediate	CRITICAL	Within 24-72 hours	13	Apache HTTP Server 2.4.49 affected by CVE-2021-42013 (10.10.0.10); Apache HTTP Server 2.4.49 affected by CVE-2022-22720 (10.10.0.10); Apache HTTP Server 2.4.49 affected by CVE-2023-25690 (10.10.0.10); OpenSSH 8.9p1 affected by CVE-2023-38408 (10.10.0.10); vsftpd 2.3.4 affected by CVE-2011-2523 (10.10.0.11)
P2 Urgent	HIGH	Within 7 days	17	OpenSSH 8.9p1 affected by CVE-2024-6387 (10.10.0.10); OpenSSH 9.7p1 affected by CVE-2024-6387 (10.10.0.12); nginx 1.18.0 affected by CVE-2021-23017 (10.10.0.14); nginx 1.18.0 affected by CVE-2021-23017 (10.10.0.14); OpenSSL 1.0.1f affected by CVE-2014-0160 (10.10.0.10)
P3 Planned	MEDIUM	Within 30 days	16	OpenSSH 8.9p1 affected by CVE-2023-48795 (10.10.0.10); OpenSSH 7.4 affected by CVE-2023-48795 (10.10.0.11); OpenSSH 7.4 affected by CVE-2018-15473 (10.10.0.11); Database service reachable over the network (10.10.0.10); FTP service exposed (cleartext credentials) (10.10.0.11)
P4 Routine	LOW	Within 90 days	11	Web service without HTTPS (10.10.0.10); Web service without HTTPS (10.10.0.13); Cleartext HTTP to Internet hosts (10.10.0.54); System auditing (auditd) is installed (web-prod-01); SSH MaxAuthTries is 4 or less (web-prod-01)

Produced by CyberShield 1.0.0 for authorised defensive use only. Automated findings should be validated by a qualified analyst before remediation decisions.